2.10【A10】基于大模型的自动化渗透测试系统开发与设计【安恒信息】

1.命题方向

智能计算 + 网络安全 + 渗透测试

2.题目类别

应用类

3.题目名称

基于大模型的自动化渗透测试系统开发与设计

4.背景说明

【整体背景】

随着云原生、微服务与API化架构普及，系统边界被不断拆分与外延，攻击面扩张带来更频繁、更链路化的安全风险暴露；与此同时，网络强国战略与数字中国建设持续推进，《网络安全法》《数据安全法》《个人信息保护法》以及等保等要求不断强化，使安全评估从“发现问题”走向“可验证、可追溯、可度量”的治理闭环。在技术层面，大语言模型在知识理解、推理规划与工具编排方面能力快速提升，为将安全测试从单点扫描升级为“决策—执行—验证—留痕”的自动化流程提供了现实路径。

【公司背景】

安恒信息技术股份有限公司（简称：安恒信息）成立于2007年，于2019年登陆科创板。作为行业领导者之一，安恒信息秉承“构建安全可信的数字世界”的企业使命，以数字经济的安全基石为企业定位，依托恒脑·安全垂域大模型，形成以DAS（D即DataSecurity-数据安全、A即AI-人工智能、S即SecurityServices-安全运营服务）为企业核心战略支撑，以网络安全、数据安全、云安全、信创安全、密码安全、安全服务等为主的数字安全能力，为逾10万家政企单位提供数字安全产品及服务。安恒信息致力于网络安全领域的研究与应用，拥有丰富的行业经验和技术积累。通过与合作伙伴的紧密合作，推动网络安全技术的发展，帮助各行各业提升信息安全防护能力。

【业务背景】

面向持续交付与高频变更的业务环境，正在探索建设能够在既定授权范围内稳定运行、自动推进并输出可复现证据的安全评估能力，以降低对个人经验的依赖，提升测试覆盖与效率，并让评估结果能够支撑整改闭环与审计要求。因此，引入大模型驱动的自动化安全测试体系，核心目标不是替代工具，而是把分散的工具能力、测试策略与验证流程编排成可持续、可复用、可度量的工程化能力。

5.项目说明

【问题说明】

当前安全测试往往跨越资产梳理、信息分析、风险假设、测试执行与结果验证多个环节，流程长且强依赖上下文理解；但常见自动化工具多以固定规则或单点检测为主，难以结合目标业务语境进行推理取舍，导致告警需要大量人工复核、漏洞链路难以闭环验证、同一目标在不同测试人员手中结果波动明显。同时，测试过程缺少统一的过程留痕与证据组织方式，难以做到可复现、可追溯与可度量，进一步放大了成本与不稳定性，制约了安全评估能力在更大范围内的规模化推广与持续运行。

【用户期望】

用户期望通过本项目实现以下目标：

（1）构建一个基于大模型的自动化安全测试系统，实现安全测试流程的智能化和自动化；

（2）利用大模型的理解与推理能力，对测试场景进行分析并辅助决策，提高测试结果的准确性与一致性；

（3）降低安全测试对人工经验的依赖，提升测试效率和覆盖范围；

（4）系统应支持 Windows 和 Linux 双平台目标环境的渗透测试，能够自动识别目标系统类型并选择相应的测试策略。

（5）集成多款安全工具，应覆盖网络扫描、漏洞扫描、Web 应用测试、暴力破解、后渗透等全测试流程；

（6）为安全测试教学、研究和实践提供可演示、可扩展的系统原型。

6.任务要求

【开发说明】

参赛学生团队需围绕本命题完成一个自动化安全测试系统的设计与实现，具体要求包括：

（1）设计清晰、合理的系统总体架构，明确各功能模块及其协作关系，采用模块化或智能体协作的系统设计思想；

（2）实现基于大模型的分析与决策机制，支持安全测试流程的自动推进，包括目标分析、漏洞识别、利用尝试、结果验证等环节；

（3）构建完整的测试流程示例，涵盖分析、执行和结果验证等关键环节，能够生成结构化的渗透测试报告

（4）系统应具备良好的可扩展性，支持新工具、新漏洞检测能力的快速集成。

【技术要求与指标】

项目在技术实现上应满足以下要求：

（1）基本技术指标

①合理使用大语言模型或相关智能计算技术，体现模型理解与推理能力，支持GPT、Claude、DeepSeek等主流模型接口；

②采用模块化或智能体协作的系统设计思想，支持功能扩展与演进；

③系统具备清晰的流程控制与结果输出机制，支持测试过程的可视化展示；

（2）功能完成度要求

①系统能够在单一目标或单一安全测试场景下，独立完成一次完整的自动化安全测试流程示范，覆盖分析、执行与结果验证等基本环节，体现系统的基本可行性与稳定性。（推荐平台：Vulnhub平台、Vulhub平台）

②在完成度方面，鼓励参赛团队在基础功能之上，进一步支持多阶段或多层级测试场景的自动化处理能力，例如涉及多节点、多环境或存在依赖关系的复杂测试场景，体现系统在复杂环境下的流程组织能力与智能决策能力。具备此类能力的项目将在技术深度与创新性方面予以重点评价。（推荐平台：Bugku平台PAR渗透测试项目）

（3）量化技术指标：

指标类别	指标项	定义	基础要求	进阶要求
漏洞检测	漏洞检测率	系统正确识别漏洞的能力	≥90%	≥95%
漏洞检测	误报率	系统报告的非漏洞占比	≤10%	≤5%
漏洞检测	CVE 覆盖度	已知 CVE 漏洞的检测能力	≥1%	≥5%
平台支持	目标系统类型	支持的目标操作系统类型	Linux 或 Windows	Linux + Windows
平台支持	靶机环境兼容	系统支持渗透测试验证的平台	Vulnhub/Vulhub	+ Bugku PAR
工具集成	工具数量	系统集成的安全工具数量	≥30 个	≥50 个
测试效率	单目标测试时间	完成单一目标测试的平均时间	≤30 分钟	≤15 分钟
系统能力	并发测试能力	同时测试多个目标的能力	≥1 个	≥3 个
系统能力	多阶段攻击支持	支持链式多阶段攻击场景	单阶段	多阶段链式
系统能力	自动报告生成	渗透测试报告生成能力	基础报告	详细报告 + 修复建议

下表所列难度为“简单”的环境系统应确保全部具备可测性与测试覆盖；在平

台能力允许范围内，尽可能支持并完成“中等”和“困难”项目的测试。

平台	名称	链接	难度
Vulnhub	Tomato	https://www.vulnhub.com/entry/tomato-1,557/	中等
Vulnhub	Earth	https://www.vulnhub.com/entry/the-planets-earth,755/	困难
Vulnhub	Jangow	http://vulnhub.com/entry/jangow-101,754/	困难
Vulnhub	Phineas	https://www.vulnhub.com/entry/phineas-1,674/	中等
Vulnhub	Odin	https://www.vulnhub.com/entry/odin-1,619/	中等
Vulhub	S2-045	https://github.com/vulhub/vulhub/tree/master/struts2/s2-045	简单
Vulhub	S2-057	https://github.com/vulhub/vulhub/tree/master/struts2/s2-057	简单
Vulhub	ThinkPHP-5.0.23-rce	https://github.com/vulhub/vulhub/tree/master/thinkphp/5.0.23-rce	简单
Vulhub	CVE-2023-21839	https://github.com/vulhub/vulhub/tree/master/weblogic/CVE-2023-21839	简单
Vulhub	CVE-2017-12615	https://github.com/vulhub/vulhub/tree/master/tomcat/CVE-2017-12615	简单
Vulhu	CVE-	https://github.com/vulhub/vulhub/blob/master/p	简单

平台	名称	链接	难度
b	2019-11043	hp/CVE-2019-11043	
Vulhub	CVE-2022-41678	https://github.com/vulhub/vulhub/blob/master/activemq/CVE-2022-41678	简单
Vulhub	CVE-2017-7504	https://github.com/vulhub/vulhub/blob/master/jboss/CVE-2017-7504	简单
Vulhub	Tomcat 8	https://github.com/vulhub/vulhub/tree/master/tomcat/tomcat8	简单
Vulhub	CVE-2016-4437	https://github.com/vulhub/vulhub/blob/master/shiro/CVE-2016-4437	简单
Vulhub	fastjson-1.2.24-rce	https://github.com/vulhub/vulhub/tree/master/fastjson/1.2.24-rce	简单
Vulhub	fastjson-1.2.47-rce	https://github.com/vulhub/vulhub/tree/master/fastjson/1.2.47-rce	简单
Vulhub	CVE-2022-34265	https://github.com/vulhub/vulhub/blob/master/django/CVE-2022-34265	简单
Vulhub	Flask-SSTI	https://github.com/vulhub/vulhub/blob/master/flask/ssti/	简单

平台	名称	链接	难度
Vulhub	CVE-2024-36401	https://github.com/vulhub/vulhub/blob/master/geoserver/CVE-2024-36401	简单

【提交材料】

（1）项目概要介绍

（2）项目简介 PPT

（3）项目详细方案

（4）项目演示视频

（5）企业要求提交的材料：

①系统架构与流程设计图

②核心功能模块说明

③项目安装指南、教学文档（需包括所有的安装步骤、实验步骤、预期结果和注意事项）

④项目的详细分工及过程文档

⑤可复现运行的公网运行环境地址

（6）团队自愿提交的其他补充材料

【任务清单】

（1）需求分析与系统设计

（2）智能体角色与协作机制设计

（3）核心功能模块实现

（4）系统集成与功能演示

【开发工具与数据接口】

项目开发可采用主流编程语言与开发框架，结合大模型调用接口及安全测试模拟环境进行实现。相关开发工具、测试环境或数据接口可由参赛团队自行选择或搭建。

7.其他

本项目仅限于合法授权的安全研究、教学、竞赛及演示场景，所有设计与实现均需遵循相关法律法规及行业规范，不得用于任何未授权或非法用途。

8.参考信息

无。

9.评分要点

赛题评分要点见附件一：A 类企业命题初赛统一评分标准。